Prompt Specification Log

Project: ATQAA_Team04_Medusa | **Course:** Advanced Testing & QA Automation (61VLSC45332201)

Team roster: Ye Yint Myint Myat (2500IT10016, Lead QE, Data & Performance) · Thae Phyu Aung Myo (2500IT10013, API Automation)

Target: Medusa.js v2.21.2 staging - Store API https://atqaa-medusa-store.onrender.com/store, Admin API /admin, Storefront https://atqaa-medusa-storefront.vercel.app/vn

Log compiled: 22 Oct 2026. AI tool used for the sessions below: Claude (Anthropic). Empirical verification executed against live staging on the same date.

Section 1 - Role-Based Prompt Specifications & Heuristics

Element	Specification
System persona	"You are a Lead QA Automation Engineer and Requirements Analyst specializing in Medusa.js headless commerce architectures."
Target context	Vercel storefront + Render backend (Medusa v2), Store API /store (requires x-publishable-api-key), Admin API /admin (JWT via /auth/user/emailpass). Single region: Vietnam (VND). Render free tier: 15-min sleep, 30-50 s cold start.
Modules	M1 Cart & Checkout (carts, line-items, shipping address/method, promotions, payment). M2 Admin Order Management (order list, fulfillment, cancellation, admin auth).
Heuristic 1: SFDPOT	Structure, Function, Data, Platform (Render/Vercel limits), Operations, Time (cold start, token expiry, concurrent checkout).
Heuristic 2: RCRCRC	Recent, Core, Risk, Configuration, Repaired, Chronic.
Output contract	Numbered risks; each with module, endpoint, test idea, expected behaviour, and confidence. AI must flag anything it is not sure exists in Medusa v2.

Section 2 - Conversation Transcripts (raw & refined)

Prompt 1 - SFDPOT sweep, Cart & Checkout (initial)

Prompt

```
[SYSTEM] You are a Lead QA Automation Engineer and Requirements Analyst specializing in
Medusa.js headless commerce architectures.
[USER] Context: Medusa.js v2 backend on Render free tier (sleeps after 15 min, 30-50 s cold
start), Next.js storefront on Vercel. Store API base /store, requires x-publishable-api-key.
Single region Vietnam (VND). Apply SFDPOT to the Cart & Checkout module. For each heuristic
list concrete, testable risks with the endpoint involved and the expected correct behaviour.
```

AI response

Structure - (1) Cart object exposes many derived totals (item_total, shipping_total, tax_total, discount_total, total); risk that derived totals drift from line items. Endpoint: GET /store/carts/{id}. Expected: total = item_total + shipping_total + tax_total - discount_total. (2) Cart is tied to a region; changing shipping country to one outside the region must be rejected.
Function - (3) POST /store/carts/{id}/line-items must reject quantity <= 0, non-integer and non-numeric quantities. (4) There should be a sensible maximum quantity per line item. (5) Invalid or expired promo codes must be rejected by POST /store/carts/{id}/promotions. (6) Payment session initialisation via POST /store/carts/{id}/payment-sessions must fail gracefully when no shipping method is selected.
Data - (7) Address fields: no documented max length; 1,000+ character names may break storage or UI. (8) Injection strings (SQL, <script>) in address fields must be rejected or neutralised. (9) Prices are stored in the smallest currency unit (cents), so a VND price of 500000 would be 5,000 VND.
Platform - (10) Cold start causes first request timeouts in CI. (11) Missing publishable key returns 400 on every /store route.
Operations - (12) Cart abandoned mid-payment leaves orphaned payment collections.
Time - (13) Two concurrent checkouts on the last unit in stock may both succeed (inventory reservation race). (14) Admin JWT expiry during long test runs.

Prompt 2 - RCRCRC sweep, Admin Order Management

Prompt

```
[USER] Same persona and context. Apply RCRCRC to Admin Order Management (order list, order
detail, fulfillment creation, cancellation). Admin auth is POST /auth/user/emailpass ->
Bearer JWT. Mark any endpoint you are not certain exists in Medusa v2.
```

AI response

> **Recent** - Medusa v2 moved auth to /auth/{actor}/{provider}; scripts written for v1 (/admin/auth/token) will fail. **Core** - GET /admin/orders filtering and pagination; order totals must equal the originating cart totals. **Risk** - Creating a fulfillment for more units than ordered; cancelling an order that is already fulfilled; refund amount greater than paid amount. **Configuration** - Single region/currency; shipping option prices configured as flat rate; tax rate may be 0 in region (verify tax_total). **Repaired** - none known for this deployment (needs team input from defect history). **Chronic** - Render latency on write operations; cold start. *Uncertain endpoints:* POST /admin/orders/{id}/fulfillments (exists in v2, verify payload), /store/carts/{id}/payment-sessions (v1 naming, may not exist in v2).

Prompt 3 - Refinement after first empirical pass

Prompt

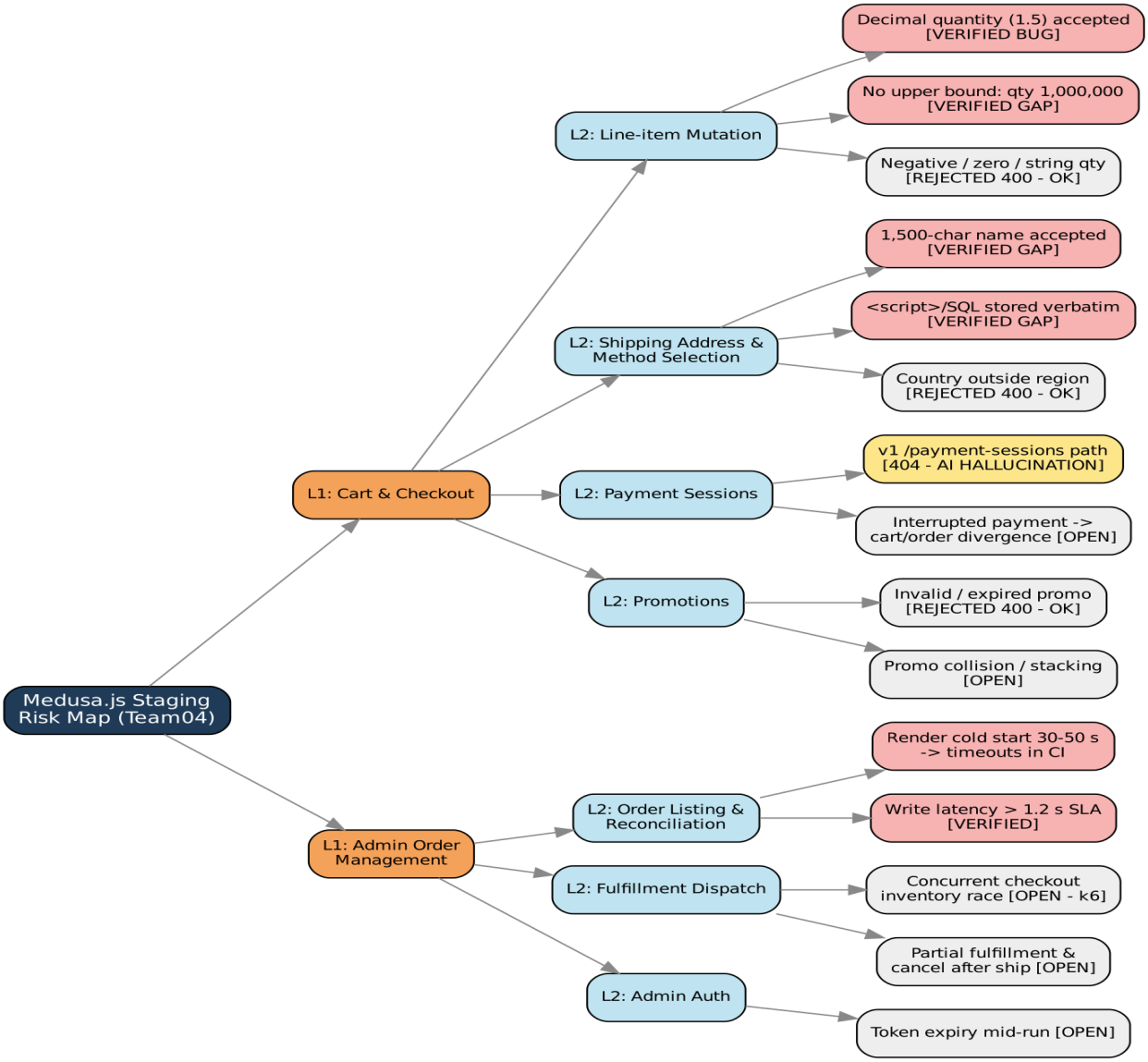
```
[USER] We verified on staging: payment-sessions route returns 404, /store/variants returns
404, quantity 1.5 and 1,000,000 are accepted, 1,500-char names and <script> strings are
stored. Prices look like major units (500000 VND for a T-shirt). Re-rank the risks by business
impact and propose acceptance criteria for the top 5 requirement gaps.
```

AI response

> Re-ranked (impact x likelihood): (1) Unbounded quantity - revenue/fraud and inventory distortion; AC: quantity is an integer 1..99 per line, else 400. (2) Non-integer quantity silently accepted - order/fulfilment mismatch; AC: reject non-integers with 400 invalid_data. (3) Unbounded text fields - storage abuse, UI breakage in admin/order emails; AC: name fields <= 100 chars, address lines <= 255. (4) Unsanitised markup stored - stored-XSS risk in admin UI, emails, PDFs; AC: reject or encode < > in personal-data fields and verify encoded rendering in Admin. (5) Write latency > 1.2 s - checkout abandonment; AC: p95 POST /store/carts/* < 1,500 ms warm on staging, cold-start handled with warm-up. Correction accepted: Medusa v2 stores amounts in major units, so risk (9) is withdrawn. Payment flow in v2 uses POST /store/payment-collections and /store/payment-collections/{id}/payment-sessions.

Teams that also used ChatGPT/Gemini should append those full transcripts here without truncation.

Section 3 - 3-Level Risk Mindmap (Module → Sub-feature → Edge case)



Red = verified on staging; yellow = AI hallucination; grey = rejected correctly or still open (to be covered by Playwright/k6).

Section 4 - AI Hallucination & Accuracy Audit Matrix

Each AI claim was checked against live staging (Medusa v2.21.2) on 22 Oct 2026 using direct API calls with the publishable key.

#	AI claim / assumption	Empirical check	Result	Verdict
1	Payment init via POST /store /carts/{id}/payment-sessions	POST to that path	404 "Cannot POST"	HALLUCINATION (v1 path). v2 uses /store/payment-collections
2	Prices stored in smallest unit (cents)	Classic T-Shirt unit_price	500000 (VND major units)	FALSE - withdrawn
3	Quantity <= 0 rejected	quantity 0 / -1	400 invalid_data	CORRECT (message says "at least 0" although 0 is rejected - minor message defect)
4	Non-integer quantity rejected	quantity 1.5	200, line accepted	FALSE - real software defect
5	Non-numeric quantity rejected	quantity "2"	400 expected number	CORRECT
6	There is a max quantity per line	quantity 1,000,000	200, cart total 500,001,000,000 VND	FALSE - spec gap
7	Long names may be rejected	first_name 1,500 chars	200, stored	Risk CONFIRMED - spec gap
8	Injection strings rejected or neutralised	last_name <script>alert(1)</script>	200, stored verbatim	Risk CONFIRMED - spec gap (verify encoding in Admin UI)
9	Country outside region rejected	country_code us	400 not within region Vietnam	CORRECT
10	Invalid promo rejected	promo_codes [FAKE2026]	400 code invalid	CORRECT
11	/store requires publishable key	GET /store/products without key	400 not_allowed	CORRECT
12	v2 admin auth is /auth/user/emailpass, not /admin/auth/token	POST /auth/user/emailpass	200 JWT	CORRECT (guideline text mentioning /admin/auth/token is v1 terminology)
13	(Guideline) GET /store/variants lists variants	GET /store/variants	404; /store/product-variants = 200	DOCUMENT ERROR - corrected in Postman collection
14	Write endpoints slow on Render	timed POST carts / line-items	1.2-1.9 s warm	CONFIRMED - NFR gap vs 1.2 s SLA